

Building a Compliant Security Profile: ND TZI and NIST Certification for ERPUNO, COURT and COD security profiles

ERPUNO Security Team

14 червня 2026 р.

Abstract

This article details the methodology for constructing a Comprehensive Information Security System (KSZI) that complies with Ukrainian state standards (ND TZI) and the international NIST SP 800-53 framework. Using SYNRC/CA — an open source CMDB we demonstrate how to programmatically define, track, and audit a security profile. The approach utilizes Elixir-based Configuration Management Database (CMDB) profiles to maintain strict accountability over hardware, software, networks, data, roles, and risks. For security reasons we can only demo/showcase of ERPUNO security (sample) profile.

Contents

1	Introduction	3
1.1	Hierarchical Security Profiles (L1, L2, L3)	3
1.2	Segregation of Duties: The Two-Stage KSZI Certification Process	4
2	Metainformational Security Profile (CMDB)	6
2.1	Detailed NIST SP 800-53 Rev.5 Control Integrations	6
2.2	Detailed ND TZI (State Standard) & ISO Compliance	9
2.3	Security Evaluation Framework	11
3	Technical Security Profile: ERP/1 Control-by-Control NIST SP 800-53 Compliance	15
3.1	Access Control (AC)	15
3.2	Audit and Accountability (AU)	19
3.3	Assessment, Authorization, and Monitoring (CA)	19
3.4	Configuration Management (CM)	20
3.5	Contingency Planning (CP)	21
3.6	Identification and Authentication (IA)	21
3.7	Incident Response (IR)	22
3.8	Maintenance (MA)	22
3.9	Media Protection (MP)	23
3.10	System and Communications Protection (SC)	23
3.11	System and Information Integrity (SI)	24
3.12	Supply Chain Risk Management (SR)	24
3.13	Planning, Risk Assessment, System Acquisition, Privacy (PL, RA, SA, PM, PT)	24
4	Organizational Security Profile	25
4.1	Awareness and Training	25
5	Conclusion	26
5.1	Codebase Overview for Copyright Registration	27

1 Introduction

ERPUNO LLC provides high-tech telecommunication solutions for the automation of commercial and state enterprises. Their platform is architecturally divided into two primary layers:

- **Platform (SYS-APP-SYNRC):** The systemic foundation, including the Certificate Authority (CA), L2/L3 VPN tunnels, PKI-aware LDAP, Communicator (CHAT), BPMN process engine, MQTT broker, and KVS storage.
- **Products (SYS-APP-ERP):** Corporate and state enterprise systems such as Education (Edu), Healthcare (Health), Electronic Documents (Mail), Accounting (Acc), Warehouse Management, and Registries (Cart).

The company's architecture is built to support critical state and defense sector needs. It offers special licensing conditions for government applications, provided there is strict adherence to architectural compatibility and certification requirements (like DSSZZI). The system strictly follows ITU-T X-series, IETF RFC, NIST/FIPS, DSTU, and ISO/IEC standards (e.g., X.509, CMS/S-MIME, AES-GCM, Kyber, DSTU 4145-2002).

In this paper, we demonstrate how to build a unified security profile for this complex architecture. The CMDB system maps operational instances directly to NIST SP 800-53 controls (such as CM-8 for System Component Inventory, PM-5 for System Inventory) and ND TZI requirements (e.g., ND TZI 3.7-003-2023 for inventory and exploitation documentation).

1.1 Hierarchical Security Profiles (L1, L2, L3)

The system supports the automated construction of KSZI security profiles based on the regulatory and legal acts in the field of technical protection of information (TZI NPA). This automates documentation generation and the mapping of legislative requirements to technical settings. All certificates are issued with OID imprints of their respective security profiles.

The architecture is divided into three levels of profiles:

1.1.1 L1: Basic Security Profiles

These profiles define the fundamental sets of controls required by the regulations.

- **SECURITY POLICIES**¹
- **FULL DIRECTORY (1123)**²
- **OPEN CONFIDENTIAL (126)**³

¹<https://ca.n2o.dev/priv/security-profiles.pdf>

²https://ca.n2o.dev/priv/bible_profile.pdf

³https://ca.n2o.dev/priv/legal_l1_profile_409.pdf

- **OFFICIAL (155)**⁴

1.1.2 L2: Industry Profiles

Industry-specific adaptations that expand upon the baseline controls to meet the requirements of specific sectors.

- **COURT INDUSTRY PROFILE**⁵: Industry security profile for the judicial system. It describes an extended set of baseline controls for processing sensitive information in state registries and courts, taking into account the requirements for high availability and data integrity based on ND TZI 3.6-006-24.
- **THE DIGITAL UKRAINIAN GOVERNMENT INDUSTRY PROFILE**⁶: Industry security profile for the Ministry of Digital Transformation of Ukraine.

1.1.3 L3: Target Security Profiles

Specific implementation targets for individual systems and components.

- **ERP/1 SECURITY TARGET**⁷: Target profile for the ERP/1 telecommunications system. Describes the implementation of Attribute-Based Access Control (ABAC), information flow management (BPE), Public Key Infrastructure (PKI), and reliable auditing (KVS) for securing critical business processes.
- **X.509 CMS MESSAGING SECURITY TARGET**⁸: Target profile for corporate messenger systems. Based on X.509 and CMS (Cryptographic Message Syntax) cryptographic protocols, providing end-to-end encryption (E2EE), strict authentication, and non-repudiation for legally significant communications.
- **VPN SECURITY TARGET**⁹: Target profile for Virtual Private Network (VPN) and PKI infrastructures. Defines mechanisms for tunneling, node authentication (SC-8), and network traffic protection at the transport layer to secure communication channels against interception and modification.

1.2 Segregation of Duties: The Two-Stage KSZI Certification Process

According to the regulatory framework of Ukraine (e.g., ND TZI 2.6-001-11) and best global practices (the *Maker/Checker* principle), building and certifying

⁴https://ca.n2o.dev/priv/legal_l1_profile_419.pdf

⁵https://ca.n2o.dev/priv/legal_l2_court_profile.pdf

⁶<https://ca.n2o.dev/priv/digital-profile.pdf>

⁷https://ca.n2o.dev/priv/legal_l3_profile_erp.pdf

⁸https://ca.n2o.dev/priv/chat_profile.pdf

⁹https://ca.n2o.dev/priv/vpn_profile.pdf

a Comprehensive Information Security System (KSZI) is strictly a **two-stage procedure**. It requires the involvement of two completely independent licensed providers to eliminate any conflict of interest.

- **Stage 1: The Developer (Provider 1).** The first provider performs the risk assessment, inspects the environment, and creates the "technical instructions" — the **Target Security Profile (Technical Specification)**. This provider is also responsible for the physical implementation of the security architecture: configuring cryptography, setting up the Reference Monitor (AC-25), installing certificates, and delivering the system into trial operation.
- **Stage 2: The Expertise Organizer (Provider 2).** The second provider receives the Technical Specification from the Developer and designs the **Expertise Program**. This provider conducts an independent technical audit, instrumental testing, and live verification of all implemented controls. Upon successful verification, they issue the Expert Conclusion for the State Service of Special Communications and Information Protection (DSSZZI).

This segregation guarantees that the organization creating the security profiles and writing the Elixir CMDB structures is legally and practically distinct from the organization auditing and approving them.

2 Metainformational Security Profile (CMDB)

Traditional KSZI (Comprehensive Information Security Systems) are often treated as static, paper-based compliance artifacts. However, for ERPUNO LLC, we engineered the KSZI as a live, programmable **Configuration Management Database (CMDB)** and **Continuous Accountability System**.

This system is inherently built into the source code using Elixir modules (e.g., `hw.ex`, `sys.ex`, `net.ex`). The core Certificate Authority (`SYS-SYNRC-CA`) acts not only as the PKI infrastructure but also as the central registry for this accountability system. The profile of this system explicitly implements the following security controls:

2.1 Detailed NIST SP 800-53 Rev.5 Control Integrations

2.1.1 CM-8: System Component Inventory

The CMDB maintains a strict, programmatically queryable registry of all hardware, software, and firmware components across the entire infrastructure. This is not merely a static spreadsheet; it is an active Elixir dataset (`hw.ex`, `sys.ex`) that tracks inventory numbers, physical locations, operational status, and cryptographic module certifications. By natively linking every physical switch, server, and HSM to its exact operational context, the system completely eradicates drift between actual infrastructure and security documentation. The inventory control ensures full visibility and reduces the attack surface by identifying rogue or unauthorized devices instantaneously.

2.1.2 CM-8(1) & CM-8(2): Inventory Updates & Tracking

The architecture guarantees the automated maintenance and tracking of component updates during all installations, removals, or migrations. Because the CMDB is stored as Elixir source code within a secure Git repository, every single alteration to the infrastructure creates an immutable, cryptographically signed commit. This mechanism automatically fulfills the requirement for strict version control and historical auditing of hardware and software lifecycles. It provides an unbroken chain of custody for all system components, essential for forensic analysis and compliance verification.

2.1.3 CM-9: Configuration Management Plan

Rather than maintaining a separate textual document that inevitably becomes obsolete, the entire Configuration Management Plan is directly codified within the repository itself, treating policy strictly as code. The build, deployment, and auditing pipelines are governed by these exact declarative profiles. Any deviation in production from the CMDB profile immediately triggers a compliance alert, ensuring the configuration management plan is actively enforced at all times. This shift from prescriptive documentation to declarative code enforces continuous compliance inherently.

2.1.4 PM-5 & PM-6: System Inventory & Measures of Performance

The `CA.PRO` API delivers real-time, system-wide inventory tracking and verifiable measures of performance to organizational stakeholders. Instead of relying on manual quarterly audits, security officers can execute programmatic queries against the CMDB to instantly extract precise metrics, asset valuations, and compliance coverage ratios, significantly reducing administrative overhead and human error. This control effectively shifts the compliance burden from human operators to automated, highly reliable programmatic interfaces.

2.1.5 CA-7: Continuous Monitoring

The security architecture integrates natively with SIEM/XDR solutions (such as Wazuh) to provide a constant, real-time status feed of all critical security controls and operational events. This continuous monitoring pipeline digests syslog, eBPF telemetry, and application logs, correlating them directly against the risk taxonomies and compliance profiles defined in the CMDB. This ensures that any degradation in security posture is immediately detected and addressed, shifting the paradigm from point-in-time assessment to perpetual situational awareness.

2.1.6 PL-2, RA-2, RA-3: Security Plans & Risk Assessments

The system implements automated system security plans, data categorization matrices, and risk taxonomies directly through the `CA.Data` and `CA.Risk` modules. Risks are not just listed; they are systematically mapped to the exact software vulnerabilities, network segments, and data stores they impact. This programmatic risk assessment allows for dynamic recalculation of the system's risk profile whenever new infrastructure is introduced. It provides a living threat model that continuously aligns security mitigations with actual business risks.

2.1.7 AC-2, AC-3 & AC-25: Access Control Enforcement & Reference Monitor

Role-based (RBAC) and Attribute-based (ABAC) access control mechanisms are centrally defined within the `roles.ex` hierarchy. These policies dictate precise permissions across all environments and are strictly enforced at the application boundary via a unified Reference Monitor (AC-25). This guarantees that all access decisions—whether for a standard user or a global administrator—are verified against the immutable policy engine before any action is permitted. Centralizing access control logically prevents bypasses and privilege escalation across disparate subsystems.

2.1.8 SC-8 & SC-28: Transmission Confidentiality & Data at Rest

Mandatory cryptographic controls are bound directly to the hardware and network profiles. For data in transit, the CMDB mandates IPsec/MACsec tunnels

across all core switches and border gateways, explicitly defining the cryptographic suites. For data at rest, Transparent Data Encryption (TDE) and hardware-level SAN encryption are mandated for all storage arrays, ensuring that physical theft or unauthorized access to drives yields zero intelligible data. These controls provide an impenetrable cryptographic envelope protecting the state’s most sensitive data assets.

2.1.9 SC-12: Cryptographic Key Establishment and Management

The **SYS-SYNRC-CA** core functions as the centralized Public Key Infrastructure (PKI), managing the entire lifecycle of all symmetric and asymmetric keys. Backed by certified Hardware Security Modules (HSMs, e.g., IIT Gryada-301), the system ensures secure key generation, escrow, rotation, and revocation. This provides an unassailable cryptographic foundation for the entire e-government platform. The rigorous key management protocol eliminates the risk of key compromise or weak cryptography being introduced ad-hoc by system administrators.

2.1.10 AU-2 & AU-6: Audit Events & Analysis

The platform defines its auditable events explicitly within the CMDB outputs, ensuring that all security-relevant activities (logons, privilege escalations, key accesses) are definitively logged. Automated mechanisms and SIEM integrations are deployed to continuously analyze these audit records for anomalous behavior, satisfying the requirement for proactive threat detection and non-repudiation of user actions. This closed-loop auditing ensures that incidents are not merely logged, but actively responded to in near real-time.

2.1.11 IA-2: Identification and Authentication

Organizational users, administrators, and automated service accounts are uniquely identified and authenticated using strict multi-factor authentication (MFA) protocols, including PKI smart cards and OTP tokens. These identities are irrevocably tied to the **roles.ex** taxonomy, preventing identity spoofing and ensuring that every session is cryptographically bound to an authorized entity. The rigorous identity management protocol establishes a zero-trust foundation where no user is trusted inherently without verifiable cryptographic proof.

2.1.12 SA-5 & PL-2: Automated System Documentation & Security Plans

The most innovative aspect of the CMDB architecture is the fulfillment of SA-5 (System Documentation) and PL-2 (System Security Plan). Instead of maintaining static text documents, the entirety of the KSZI documentation—including the overarching security plans, asset registries, risk matrices, and this very PDF report—is automatically generated directly from the live Elixir source code. By compiling the current system state into documentation on demand via

a "Documentation as Code" (DaC) paradigm, the organization completely eliminates the phenomenon of "documentation drift." This guarantees that auditors and state regulators always evaluate a 100% accurate reflection of the deployed system, significantly reducing the cost and friction of DSSZZI and NIST compliance audits.

2.1.13 CP-9 & CP-10: Information System Backup & Recovery

The categorization of data assets within the CMDB directly governs the automated backup schedules. Critical databases and file stores are subjected to continuous replication, while sensitive offline archives are routed to air-gapped tape libraries (e.g., HPE StoreEver). This guarantees robust disaster recovery capabilities and strict protection against ransomware or catastrophic hardware failures. The recovery protocols ensure minimal recovery point objectives (RPO) and recovery time objectives (RTO), crucial for high-availability enterprise services.

2.2 Detailed ND TZI (State Standard) & ISO Compliance

2.2.1 ND TZI 3.7-003-2023 §4.2 & §5: Exploitation Documentation

According to Ukrainian state standards, the accountability of protected objects and the generation of exploitation documentation are critical for state expertise. This system automatically generates all required technical passports, inventory logs, and component registries directly from the `inventory_num` and `serial` fields within the CMDB. This completely eliminates manual paperwork and ensures absolute accuracy during DSSZZI audits. This automation accelerates the certification process and removes the human error typically associated with maintaining extensive paper-based documentation.

2.2.2 ND TZI 1.6-005-22 & 2.6-001-11: State Expertise Audit Trails

Security requirements and audit trails required for the State Expertise of the KSZI are dynamically extracted from the `controls` field embedded within each profile. The system can instantly produce a complete mapping of implemented controls against the regulatory requirements, providing auditors with transparent, code-backed evidence of compliance rather than unverifiable assertions. This verifiable link between state regulation and physical implementation provides unparalleled assurance during regulatory inspections.

2.2.3 ND TZI 2.5-004-99 & 2.5-005-99: System Classification & Evaluation

The automated system classification and security evaluation criteria are continuously verified against the defined target profile. Instead of periodic manual assessments, the CMDB mechanism ensures that any architectural change triggers a re-evaluation of the system class (e.g., Class 2 or 3), ensuring that the

protection profile remains consistently aligned with the nature of the processed data. This continuous classification guarantees that the system never inadvertently drifts into a non-compliant state due to infrastructure modifications.

2.2.4 ND TZI 3.6-006-24: Critical State Registries

The architecture fully supports the strict baseline requirements for critical state registries and judicial systems. It guarantees exceptional high availability (HA) across all nodes and mandates deep cryptographic integrity of evidentiary data utilizing national cryptographic algorithms (DSTU 4145-2002 for digital signatures, DSTU 7564-2014 for hashing), fulfilling the most stringent requirements for electronic governance. Compliance with this standard ensures the legal validity of electronic documents processed within the ERP system.

2.2.5 ND TZI 2.5-008-02: Confidential Information Protection

The system strictly adheres to the requirements for protecting confidential and restricted state information. The dynamic categorization mechanism evaluates the sensitivity of each data asset and dictates the requisite level of cryptographic segregation and physical protection (e.g., mandating air-gapped environments or specific HSM usage) required to legally process that data. The classification matrix automatically enforces the principle of least privilege, isolating highly sensitive segments away from standard user workflows.

2.2.6 ND TZI 2.5-010-03: Web Application Protection

Protection of web-facing applications from unauthorized access and malicious exploitation is handled proactively. The network profiles (`net.ex`) explicitly declare the placement and configuration of Web Application Firewalls (WAF) and deep packet inspection (DPI) mechanisms. Coupled with the ABAC filters, this ensures that web vulnerabilities are mitigated at the network boundary before reaching the application logic. The defense-in-depth approach nullifies common web exploitation vectors prior to authentication.

2.2.7 ISO/IEC 27001:2022 & DSTU ISO/IEC 27001:2015: ISMS Alignment

The entire CMDB-driven approach aligns perfectly with the core tenets of an Information Security Management System (ISMS). By treating the inventory, risk assessment, and access control matrices as live code, the system intrinsically supports the ISO requirements for continuous improvement (Clause 10), comprehensive asset management (Annex A.8), and stringent logical access controls (Annex A.9). This programmatic integration effectively transforms the ISMS from a theoretical framework into an operational enforcement mechanism.

By transforming compliance into code, the CMDB guarantees that the operational reality of the infrastructure is continuously synchronized with the certified KSZI documentation.

2.3 Security Evaluation Framework

The following sections provide the complete execution traces of the CMDB profile extraction for the "ERP" system. These outputs demonstrate how the infrastructure is documented, maintained, and continuously monitored.

2.3.1 Risk Assessment (CA.PRO.risk)

The risk taxonomy enumerates the identified threats and binds them to the corresponding security control families.

```
iex> CA.PRO.risk("ERP")
[
{"RISK-OS-01", "Вразливості Active Directory (Kerberoasting, Pass-the-Hash, Golden Ticket)", ["AC", "IA", "SC"]},
{"RISK-OS-02", "Зловживання WMI та PowerShell (Fileless-методи)", ["SI", "SC", "CM"]},
{"RISK-OS-03", "Вразливості на рівні ядра (BYOVD, Ring 0)", ["SI", "CM"]},
{"RISK-OS-04", "Маніпуляція маркерами доступу (Token Stealing)", ["AC", "AU"]},
{"RISK-OS-05", "Некоректні дозволи NTFS / Share (Orphaned SIDs)", ["AC", "CM"]},
{"RISK-OS-06", "Підвищення привілеїв Linux (Kernel, SUID, Dirty COW)", ["AC", "SI"]},
{"RISK-OS-07", "Втеча з контейнерів Docker/Kubernetes", ["SC", "CM"]},
{"RISK-OS-08", "Зловживання eBPF (прихований моніторинг)", ["AU", "SI"]},
{"RISK-OS-09", "Ін'єкції динамічних бібліотек (LD_PRELOAD)", ["SI", "CM"]},
{"RISK-OS-10", "Вразливості PAM (обхід автентифікації)", ["IA", "AC"]},
{"RISK-OS-11", "Обхід XProtect / Gatekeeper / SIP (macOS)", ["CM", "SI"]},
{"RISK-OS-12", "Компрометація macOS Keychain", ["IA", "SC"]},
{"RISK-OS-13", "TCC Bypass & Spyware (macOS)", ["SI", "PE"]},
{"RISK-OS-14", "Dyld Hijacking (macOS)", ["SI"]},
{"RISK-OS-15", "Обхід Pointer Authentication PAC (Apple Silicon)", ["SI", "SA"]},
{"RISK-CRY-01", "Пост-квантові загрози SNL (Store Now, Decrypt Later)", ["SC", "RA", "SA"]},
{"RISK-CRY-02", "Атаки сторонніми каналами (DPA, таймінг, EM)", ["SC", "PE", "SA"]},
{"RISK-CRY-03", "Fault Injection (Glitching, Voltage Drop)", ["PE", "SI", "SC"]},
{"RISK-CRY-04", "Компрометація ПАК «Грядя» (IIT HSM)", ["PE", "SC", "AC"]},
{"RISK-CRY-05", "Екстракція ключів з HKI e-Токен (IIT)", ["PE", "SC"]},
{"RISK-CRY-06", "Вразливості ASN.1 парсерів X.509 / CMS", ["SI", "SA"]},
{"RISK-CRY-07", "Вразливості криптобібліотек ДСТУ (Калина, Купина, Padding Oracle)", ["SA", "SI"]},
{"RISK-CRY-08", "Недостатня ентропія генератора псевдовипадкових чисел (PRNG)", ["SC"]},
{"RISK-CRY-09", "Втрата або перехоплення PIN-кодів HSM (кейлогери)", ["IA", "AT", "PE"]},
{"RISK-CRY-10", "Фізична деструкція носіїв «Автор» (CryptoCard)", ["PE", "MP"]},
{"RISK-CRY-11", "Вразливості CCID драйверів токенів (ескаляція привілеїв)", ["SI", "CM"]},
{"RISK-CRY-12", "Підміна сесій PKCS#11 (MitM між ПЗ ЦСК та HSM)", ["SC", "SI"]},
{"RISK-NET-01", "BGP Hijacking & Route Leaks (підміна анонсів AS)", ["SC", "SI"]},
{"RISK-NET-02", "Атаки L2 (VLAN Hopping, ARP Spoofing, STP атаки)", ["SC", "AC"]},
{"RISK-NET-03", "Вразливості IPSec / VPN (IKE downgrade, PSK витік)", ["SC", "IA"]},
{"RISK-NET-04", "DDoS (Slowloris, SYN Flood, ампліфікація DNS/NTP)", ["SC", "IR"]},
{"RISK-NET-05", "Компрометація Wi-Fi (KRACK, PMKID, Evil Twin)", ["SC", "IA"]},
{"RISK-NET-06", "Вразливості DNSSEC (DNS Spoofing, помилки конфігурації)", ["SC", "SI"]},
{"RISK-NET-07", "Відкриті інтерфейси управління (SNMPv1/v2, Telnet, REST API)", ["CM", "AC", "SC"]},
{"RISK-INF-01", "Компрометація BMC (IPMI, iDRAC, iLO)", ["AC", "SC"]},
{"RISK-INF-02", "Вразливості Firmware / UEFI Bootkits", ["SI", "SA"]},
{"RISK-INF-03", "Атаки на мікроархітектуру CPU (Spectre, Meltdown)", ["SI", "SC"]},
{"RISK-INF-04", "Cold Boot & Rowhammer атаки на пам'ять", ["PE", "SI"]},
{"RISK-INF-05", "Відмова дискових масивів SAN/NAS (Split-brain)", ["CP", "SI"]},
{"RISK-INF-06", "Електромагнітне випромінювання TEMPEST", ["PE", "SC"]},
{"RISK-INF-07", "Відмова інженерних систем (UPS, дизель, чиллер, пожежогасіння)", ["PE", "CP"]},
{"RISK-PER-01", "Spear Phishing & Whaling (цільовий фішинг адміністраторів)", ["AT", "IR", "SI"]},
{"RISK-PER-02", "Watering Hole Attacks (компрометація профільних ресурсів)", ["SI", "AT"]},
{"RISK-PER-03", "Інсайдерський саботаж та експільтрація (логічні бомби)", ["PS", "AU", "AC"]},
{"RISK-PER-04", "Pretexting / Baiting / Tailgating (фізичний доступ)", ["AT", "PE", "PS"]},
{"RISK-PER-05", "Credential Stuffing (словники та бази паролів)", ["IA", "AT"]},
{"RISK-SYNC-01", "Race Condition (стан гонитви у спільних ресурсах)", ["SI", "SA"]},
{"RISK-SYNC-02", "TOCTOU (Time-of-Check to Time-of-Use)", ["SI", "AC"]},
{"RISK-SYNC-03", "NTP Spoofing (десинхронізація часу)", ["SC", "AU", "SI"]},
{"RISK-SYNC-04", "Split-Brain у кластерах СУБД", ["CP", "SI"]},
{"RISK-SYNC-05", "Replication Lag (вікно доступу до застарілих даних)", ["SI", "SC"]},
{"RISK-DAT-01", "Втрата резервних копій (Ransomware, Backup Corruption)", ["CP", "MP", "SI"]},
```

```
{ "RISK-DAT-02", "Витік електронних судових справ (несанкціонований доступ)", ["AC", "SC", "PE"]}
]
```

2.3.2 System Software Components (CA.PRO.sys)

The system inventory documents all OS, middleware, platform, and application-level software components running in the environment, satisfying NIST CM-8 and PM-5.

```
iex> CA.PRO.sys("ERP")
[
  {"SYS-OS-01-UAL", "UA Linux 24.04 LTS (ДСТУ-hardened, SELINUX Enforcing) (24.04 LTS)", []},
  {"SYS-OS-01-WIN", "Windows Server 2025 Datacenter (NATO STIG + DISA hardened) (2025 Datacenter)", []},
  {"SYS-OS-01-ESX", "VMware ESXi 8.0 Update 3 (vSphere Foundation) (8.0 U3)", []},
  {"SYS-OS-02-W11", "Windows 11 Pro 24H2 (DISA STIG + Windows Defender Credential Guard) (24H2 (Build 26100))", []},
  {"SYS-OS-02-UAL", "UA Linux Desktop 24.04 LTS (ДСТУ, GNOME Hardened) (24.04 LTS Desktop)", []},
  {"SYS-APP-00-ERL", "Erlang/OTP 27.3 (SMP, BEAM VM, distribution TLS) (27.3)", []},
  {"SYS-APP-00-ELX", "Elixir 1.18.3 (N20, NITRO, FORM, Bandit) (1.18.3)", []},
  {"SYS-APP-00-EMQ", "EMQ X 2.12 (MQTT 5.0 / MQTT-SN, Erlang/OTP cluster) (2.12)", []},
  {"SYS-SYNRC-CA", "Сертифікати (7.4)", []},
  {"SYS-SYNRC-VPN", "Тунелі (1.0)", []},
  {"SYS-SYNRC-LDAP", "Директорія (1.0)", []},
  {"SYS-SYNRC-CHAT", "Комунікатор (4.2)", []},
  {"SYS-SYNRC-BPMN", "Процеси (6.11)", []},
  {"SYS-SYNRC-MQTT", "Брокер (2.12)", []},
  {"SYS-SYNRC-KVS", "Сховище (10.0)", []},
  {"SYS-SYNRC-WS", "Фреймворк (11.0)", []},
  {"SYS-SYNRC-FORM", "Форми (1.3)", []},
  {"SYS-SYNRC-ASN1", "Компілятор (1.0)", []},
  {"SYS-SYNRC-ABAC", "Контроль (1.0)", []},
  {"SYS-ERP-EDU", "Освіта (1.0)", []},
  {"SYS-ERP-HEALTH", "Здоров'я (1.0)", []},
  {"SYS-ERP-MAIL", "Документи (1.0)", []},
  {"SYS-ERP-ACC", "Облік (1.0)", []},
  {"SYS-ERP-WAREHOUSE", "Склад (1.0)", []},
  {"SYS-ERP-CART", "Реєстри (1.0)", []},
  {"SYS-APP-01-IIT", "ІІТ Користувач ЦКК-1 (бібліотека <ІІТ Gryada-301>) (3.0.1)", []},
  {"SYS-APP-01-CIP", "Сайффер HSM Middleware (PKCS#11 + CMS + TSP клієнт) (2.8)", []},
  {"SYS-APP-01-SIGN", "Автоматичне Підписання (batch signing, LTV, XAdES-BES) (5.2)", []},
  {"SYS-APP-02-WZ", "Wazuh 4.9 SIEM/XDR (OSSEC-based, FIM, compliance CIS/NIST) (4.9)", []},
  {"SYS-APP-02-ZBX", "Zabbix 7.2 (active agents, encrypted PSK transport, alerting) (7.2 LTS)", []},
  {"SYS-DB-01-PG", "PostgreSQL 17.2 (TDE + pgAudit + pg_partman) (17.2)", []},
  {"SYS-DB-01-ORA", "Oracle Database 23ai (Advanced Security Option, TDE, Vault) (23ai (23.5))", []},
  {"SYS-DB-02-RDS", "Redis 7.4 (TLS 1.3, ACL, persistence RDB+AOF) (7.4)", []},
  {"SYS-INF-01-VBR", "Veeam Backup & Replication 12.3 (immutable backups, SureBackup) (12.3)", []},
  {"SYS-INF-01-BCL", "Bacula Community 15.0 (offline tape + air-gapped archive) (15.0)", []},
  {"SYS-MW-01-NGX", "Nginx 1.27 (TLS 1.3 only, OCSP Stapling, CT Logs, HSTS) (1.27)", []},
  {"SYS-MW-01-HAP", "HAProxy 3.0 (HA pair, health checks, rate limiting) (3.0 LTS)", []},
  {"SYS-MW-02-AD", "Active Directory Domain Services 2025 (LAPS v2, Protected Users, Tiering) (Windows Server 2...)", []},
  {"SYS-MW-02-IPA", "FreeIPA 4.12 (Kerberos V, OTP, CA sub-ідентифікатор) (4.12)", []}
]
```

2.3.3 Hardware Inventory (CA.PRO.inventory)

The hardware inventory explicitly tracks physical assets, cryptographic modules (HSMs), network appliances, and storage arrays.

```
iex> CA.PRO.inventory("ERP")
[
  {"ERP-STG-01", "ERP-STG-2025-001", "5HT Technology AllFlash NVMe Array (Sapphire Rapids Storage Controller)"},
  {"ERP-STG-02", "ERP-STG-2025-002", "5HT Technology AllFlash NVMe Array"},
  {"ERP-TAPE-01", "ERP-STG-2025-003", "HPE StoreEver MSL3040 Tape Library"},
  {"ERP-WS-01", "ERP-WS-2025-001", "5HT Technology Workstation Compact (Sapphire Rapids)"},
]
```

```

{"ERP-WS-02", "ERP-WS-2025-002", "5HT Technology Workstation Compact (Sapphire Rapids)"},
{"ERP-KZI-01", "ERP-KZI-2025-001", "IIT Gryada-301 PCIe HSM"},
{"ERP-KZI-02", "ERP-KZI-2025-002", "IIT Gryada-301 PCIe HSM"},
{"ERP-KZI-03", "ERP-KZI-2025-003", "Австр CryptoCard Smart-01 (e-Токен, Смарт-карта)"},
{"ERP-NET-01", "ERP-NET-2025-001", "Cisco Catalyst 9500-48Y4C"},
{"ERP-NET-02", "ERP-NET-2025-002", "Cisco Catalyst 9500-48Y4C"},
{"ERP-NET-03", "ERP-NET-2025-003", "Cisco ASR 1002-HX Router"},
{"ERP-FW-01", "ERP-NET-2025-004", "Cisco Firepower 4145 NGFW (FTD 7.6)"},
{"ERP-FW-02", "ERP-NET-2025-005", "Cisco Firepower 4145 NGFW (FTD 7.6)"},
{"ERP-SRV-01", "ERP-2025-001", "5HT Technology Tristellar 3U"},
{"ERP-SRV-02", "ERP-2025-002", "5HT Technology Tristellar 3U"},
{"ERP-SRV-03", "ERP-2025-003", "5HT Technology Quadstellar 4U"},
{"ERP-SRV-04", "ERP-2025-004", "5HT Technology Quadstellar 4U"},
{"ERP-SRV-05", "ERP-2025-005", "5HT Technology Tristellar 3U"},
{"ERP-SRV-06", "ERP-2025-006", "5HT Technology Tristellar 3U"},
{"ERP-SRV-07", "ERP-2025-007", "5HT Technology Tristellar 3U"},
{"ERP-SRV-08", "ERP-2025-008", "5HT Technology Tristellar 3U"}
]

```

2.3.4 Role-Based Access Control (CA.PRO.roles)

The defined roles establish the baseline for the Attribute-Based Access Control (ABAC) and Role-Based Access Control (RBAC) mechanisms.

```

iex> CA.PRO.roles("ERP")
[
  {"ROLE-ADM-01", "Адміністратор безпеки", ["security_admin"]},
  {"ROLE-AUD-01", "Аудитор", ["auditor"]},
  {"ROLE-OPR-01", "Оператор реєстрації", ["reg_operator"]},
  {"ROLE-SYS-01", "Системний процес (Machine-to-Machine)", ["ocsp_service", "crl_generator"]},
  {"ROLE-SADM-01", "Глобальний суперадміністратор (root/administrator)", ["global_root_admin", "infra_super_user"]}
]

```

2.3.5 Data Categorization (CA.PRO.data)

Data categorization ensures that sensitive information (e.g., PII, keys) is stored in the appropriate encrypted and access-controlled repositories.

```

iex> CA.PRO.data("ERP")
[
  {"DATA-PUB-01", "Публічні сертифікати та CRL", "Public CDN / web server"},
  {"DATA-PUB-02", "Політики ЦСК (CPS, CP)", "Public web server"},
  {"DATA-PII-01", "Реєстр підписників (паспорти, ФНОКПП)", "Encrypted DB (PostgreSQL)"},
  {"DATA-PII-02", "Адресні та контактні дані підписників", "Encrypted DB (PostgreSQL)"},
  {"DATA-INT-01", "Внутрішні накази та регламенти", "Internal file server"},
  {"DATA-INT-02", "Журнали аудиту (SIEM logs)", "SIEM (Elasticsearch)"},
  {"DATA-KEY-01", "Кореневі та підпорядковані ключі ЦСК", "HSM (Грядя / IIT)"},
  {"DATA-KEY-02", "Паролі та секрети адміністраторів", "Password Manager (Vault)"},
  {"DATA-CRT-01", "Матеріали судових проваджень та ухвали", "Encrypted DB (Oracle / PostgreSQL)"},
  {"DATA-CRT-02", "Електронні докази (обмежений доступ)", "Encrypted storage (Scality RING)"},
  {"DATA-BKP-01", "Снапшоти БД та образи ВМ", "Tape Library (MSL3040)"},
  {"DATA-BKP-02", "Офлайн-архіви судових документів", "Air-gapped Tape (offline)"}
]

```

2.3.6 Business Processes (CA.PRO.proc)

The documentation of business processes connects operational workflows with their responsible actors, ensuring accountability.

```

iex> CA.PRO.proc("ERP")
[
  {"PROC-CERT-01", "Видача кваліфікованих сертифікатів", "Оператор реєстрації ЦСК"},
  {"PROC-OCSP-01", "Формування OCSP-відповідей (24/7)", "Автоматичний сервіс ЦСК"},
  {"PROC-AUDIT-01", "Логування та моніторинг подій безпеки", "Адміністратор безпеки / SIEM"},
  {"PROC-ROOT-01", "Церемонія генерації кореневого ключа", "Комісія ЦСК (Dual Control)"},
  {"PROC-DOC-01", "Реєстрація та розгляд судових справ", "Судова влада України / ДП ICC"},
  {"PROC-BKP-01", "Резервне копіювання та відновлення", "Адміністратор резервного копіювання"}
]

```

2.3.7 Network Architecture (CA.PRO.net)

The network segmentation profile details the logical separation of DMZ, internal, management, and air-gapped zones to prevent lateral movement.

```

iex> CA.PRO.net("ERP")
[
  {"NET-DMZ-01", "OCSP / CRL публічний ендпоінт", "публічна підмережа"},
  {"NET-DMZ-02", "Веб-портал ЦСК", "публічна підмережа"},
  {"NET-INT-01", "Сегмент серверів БД", "внутрішня підмережа БД"},
  {"NET-INT-02", "Сегмент робочих станцій операторів", "внутрішня підмережа АРМ"},
  {"NET-MGT-01", "VLAN IPMI / iLO адміністрування", "management VLAN"},
  {"NET-AIR-01", "Кореневий ЦСК (офлайн вузол)", "N/A"}
]

```

3 Technical Security Profile: ERP/1 Control-by-Control NIST SP 800-53 Compliance

The following section is a comprehensive, control-by-control scientific analysis of how the components of the ERP/1 platform (ecosystem `ERP.UNO`, `N20.DEV`, `SYNRC.COM`) naturally and architecturally satisfy the requirements of NIST SP 800-53 Rev.5 and ND TZI 2.3-025-24. Each platform product is a purpose-built solution for a specific security domain, enabling maximally organic — without artificial mappings — standard compliance. The analysis covers all 20 control families: AC, AT, AU, CA, CM, CP, IA, IR, MA, MP, PE, PL, PM, PS, PT, RA, SA, SC, SI, SR.

3.1 Access Control (AC)

3.1.1 `zencrypted/ias`: AC-2 — Account Management

The `ias` server (Identity and Access Server) is the platform's central Identity Provider (IdP), implementing the full account lifecycle through a single programmatic interface. Unlike fragmented LDAP directories, `ias` operates with declarative user profiles directly bound to the role registry in `roles.ex`.

AC-2(1) — Automated System Account Management. `ias` supports SCIM 2.0 (System for Cross-domain Identity Management) for automatic synchronization of account state across subsystems. When an event arrives from an HR module (e.g., ERP/EDU or ERP/HEALTH), `ias` automatically performs provisioning or de-provisioning without manual intervention, guaranteeing compliance with the Joiner-Mover-Leaver (JML) requirements.

AC-2(2) — Removal of Temporary and Emergency Accounts. Temporary accounts in `ias` have mandatory fields `expires_at` and `account_type:temporary`. A background scheduler (implemented via Erlang/OTP `:timer`) inspects the database hourly and automatically deactivates expired records. Setting an expiration time is a required parameter when creating a temporary account.

AC-2(3) — Disable Inactive Accounts. The `ias` server stores a `last_seen_at` timestamp for each session. If the value exceeds a configurable threshold (default: 90 days), the account is transitioned to the `:inactive` state, with an automatic notification sent to the security administrator.

AC-2(4) — Automated Audit Actions. Any change in account state (creation, privilege modification, deactivation, deletion) generates a signed record in the `kvs` audit log via event sourcing. This provides an immutable, cryptographically protected trail of all administrative actions.

AC-2(5) — Inactivity Logout. `ias` centrally manages session duration. The `session_idle_timeout` setting is a global parameter and can be overridden at the role level (e.g., a stricter 15-minute limit for administrators).

AC-2(6) — Dynamic Privilege Management. Since `ias` is integrated with `erpuno/abac`, privileges are not static profile attributes but dynamically

computed decisions from the Policy Decision Point. This means elevated privileges (e.g., administrator mode for critical operations) are activated only for the duration of a specific session and for a specific resource.

AC-2(7) — Role-Based Schemes. The integration of `ias` with `roles.ex` allows roles to be organized hierarchically (RBAC). Role templates are inherited: the `auditor` role automatically receives all rights of the parent `read_only` role, without requiring duplication of rules.

AC-2(8) — Dynamic Account Management. For service accounts (machine-to-machine), `ias` supports OAuth 2.0 Client Credentials with short-lived tokens (TTL: 15 minutes). Services have no permanent password, eliminating the risk of long-term secret leakage.

AC-2(9) — Restrictions on Use of Shared and Group Accounts. The `ias` architecture does not allow creating "shared" accounts by default. Every subject — person or service — has a unique cryptographic identifier bound to an X.509 certificate issued by `synrc/ca`.

AC-2(10) — Shared and Group Account Credential Change. For technical group accounts (e.g., `ocsp_service`), `ias` implements a "secret rotation" mechanism triggered by every change in group membership, automatically generating a new key pair via `synrc/ca`.

AC-2(11) — Usage Conditions. Upon login, `ias` checks the currency of accepted terms of use. If the `terms_of_service_version` in the profile does not match the current version, access is blocked until the new terms are accepted.

AC-2(12) — Account Monitoring for Atypical Usage. Behavioral metrics (request frequency, geography, unusual hours) are aggregated by `ias` and forwarded to SIEM (Wazuh). When the behavioral baseline is exceeded, an incident is automatically created in `erpuno/itsm`.

AC-2(13) — Disable Accounts of High-Risk Individuals. SIEM integration allows `ias` to receive webhook signals about compromise. Upon receiving a `high_risk_account_detected` signal, the corresponding profile is transitioned to `:suspended` within one second, regardless of any currently active sessions.

3.1.2 `zencrypted/ias`: AC-7 — Unsuccessful Logon Attempts

AC-7 (Base Control). `ias` maintains a counter of failed authentication attempts bound to the subject and IP address. After a configurable threshold (default: 5 attempts in 10 minutes), the account is temporarily locked (account lockout) with an automatic notification to the administrator.

AC-7(2) — Purge or Wipe Mobile Device. Upon receiving a signal from a Mobile Device Management (MDM) system about device theft or compromise, `ias` immediately revokes all tokens and certificates associated with that device via the OCSP revocation mechanism in `synrc/ca`.

3.1.3 `synrc/ca`: AC-3 — Access Enforcement

The `synrc/ca` module implements the Reference Monitor (AC-25) — a centralized control mechanism that verifies every request to a protected resource based on X.509 certificates and ABAC policies.

AC-3(3) — Mandatory Access Control. `synrc/ca` supports data classification labels (Data Labels) in X.509 certificate extensions. This enables enforcement of the Mandatory Access Control (MAC) principle: a certificate with a `confidential` clearance level cannot access a resource labeled `secret`, even if an RBAC rule formally permits it.

AC-3(4) — Discretionary Access Control. Resource owners can delegate access rights via the attributed token mechanism of `ias`, implementing the classic DAC (Discretionary Access Control) model. Delegation is always bounded by the delegating subject’s own permissions.

AC-3(7) — Role-Based Access Control. RBAC is implemented at the X.509 extension level, where the `SubjectAlternativeName` field contains role URNs. This means a role is cryptographically bound to a person and confirmed by the digital signature of the root CA, making forgery or substitution of a role technically impossible.

AC-3(10) — Audited Override of Access Control Mechanisms. For services using JWT or SAML, `ias` generates signed claims with a time-limited validity. `synrc/ca` acts as the authority issuing short-lived assertion tokens whose verification requires no query to the IdP (stateless verification).

AC-3(11) — Restrict Access to Specific Information Types. Isolation between ERP/1 tenants (e.g., between different courts or agencies) is implemented at the Kubernetes namespace level and through unique root certificates for each tenant, issued by `synrc/ca`.

AC-3(12) — Assert and Enforce Application Access. The `abac` access decision incorporates a set of attributes: `subject.role`, `subject.clearance`, `resource.classification`, `action.type`, `environment.time`, `environment.network_zone`. This ensures context-aware access in accordance with the Zero Trust principle.

AC-3(13) — Attribute-Based Access Control. Subject attributes are stored in `ias` and `synrc/ca`; resource attributes in KVS metadata. `abac` retrieves them at decision time, guaranteeing attribute freshness even under frequent context changes.

AC-3(15) — Discretionary and Mandatory Access Control. The system supports the simultaneous operation of two models: MAC (based on classification labels in X.509) and DAC (delegation via `ias`). MAC always takes priority: if a mandatory label denies access, a DAC rule cannot override it.

3.1.4 `synrc/bpmn`: AC-4 — Information Flow Enforcement

The BPMN engine `synrc/bpmn` is the central orchestrator of business processes, and all information flows between platform components pass through it.

AC-4 (Base Control). Every data transition between business process

tasks (BPMN Tasks) is a controlled event. `bpmn` implements "information gateways" — process nodes that verify data classification before transfer between network segments or tenants.

AC-4(1) — Object Security and Privacy Attributes. Artifacts (documents, case files) passed between tasks carry a mandatory `data_classification` attribute. The BPMN gateway rejects the transfer if the artifact's classification does not match the permitted level of the target process segment.

AC-4(4) — Flow Control of Encrypted Information. At boundaries between organizational units, `bpmn` performs schema validation of transferred documents (JSON Schema, XSD) and verification of CMS/XAdES signatures before continuing the process.

3.1.5 `erpuno/abac`: AC-5 and AC-6 — Separation of Duties and Least Privilege

AC-5 — Separation of Duties. `abac` implements Separation of Duties (SoD) via declarative XACML-like rules specifying sets of mutually exclusive roles (SSD: Static Separation of Duties). For example, the same individual cannot hold both the `initiator` and `approver` roles for financial transactions. SoD rules are verified not only at action execution but also at role assignment — the system rejects an assignment that would create a conflict.

AC-6 — Least Privilege. The fundamental principle of `abac`: access is denied by default (Default Deny). Permission is granted only when an explicit, positive matching rule exists. Rules have the minimum necessary scope — bound to a specific resource, action, and context.

AC-6(1) — Authorize Access to Security Functions. Instead of static privilege grants, `abac` computes privileges dynamically based on current subject and context attributes. Elevated rights (e.g., BreakGlass mode operations) are temporary and automatically revoked after the critical operation completes.

AC-6(2) — Non-Privileged Access for Non-Security Functions. `abac` ensures that administrative roles (e.g., `security_admin`) do not have access to business functions (court records, medical data) by default. The security administrator administers *the system*, not *the data* of the system.

AC-6(3) — Network Access to Privileged Commands. Privileged commands (service restarts, configuration changes) are accessible only via a dedicated Management VLAN, not through the general network interface. `abac` checks the `environment.network_zone` attribute in every request.

AC-6(4) — Separate Processing Domains. For example, a CA registration operator may *submit* a certificate request, but only the CA administrator may *sign* it. This two-stage approval (Maker/Checker) is hard-coded in the BPMN process and ABAC rules.

AC-6(5) — Privileged Accounts. The list of privileged accounts (e.g., `global_root_admin`) is defined in `roles.ex` and subject to monthly audit (control AC-2(12)). The number of subjects in this group is minimized and documented.

AC-6(7) — Review of User Privileges. Quarterly, `ias` automatically generates a `privileged_access_review_report` listing all subjects with elevated rights, last-login dates, and anomalies. The report is forwarded to the CISO.

AC-6(9) — Log Use of Privileged Functions. Every execution of a privileged action is logged as a separate record in `kvs` with full context: subject, role, action, time, IP, hash of the executed command. These records are *immutable* due to the append-only nature of KVS.

AC-6(10) — Prohibit Non-Privileged Users from Executing Privileged Functions. Technically enforced through the combination of ABAC rules and X.509 cryptographic mandates: privileged API endpoints require the presence of a specific OID extension in the certificate, which is issued only upon explicit assignment of a privileged role.

3.2 Audit and Accountability (AU)

3.2.1 `zencrypted/ias`: AU-2, AU-3, AU-6, AU-9, AU-10, AU-12

AU-2 — Event Logging. `ias` is the primary source of most security events: login/logout, failed authentications, profile changes, privilege delegation. The event list is defined in configuration and complies with ND TZI 2.3-025-24 mandatory logging requirements.

AU-3 — Content of Audit Records. Each `ias` audit record contains: `timestamp` (millisecond precision, NTP-synchronized), `subject_id`, `event_type`, `resource_id`, `action`, `outcome` (success/failure), `source_ip`, `session_id`, `signature` (HMAC record signature).

AU-6 — Audit Record Review, Analysis, and Reporting. `ias` logs are automatically forwarded to SIEM (Wazuh) via secured syslog. Wazuh applies NIST and CIS correlation rules to detect anomalies and generate alerts.

AU-9 — Protection of Audit Information. Audit records are stored in `kvs` with DSTU 7564-2014 (Kupyna) hashing. Any unauthorized modification of a record is detected upon the next chain verification.

AU-10 — Non-Repudiation. Critical events (document signing, approvals, certificate issuance) are recorded with RFC 3161 TSP timestamps from a trusted TSA provider, guaranteeing the legal evidentiary weight of records in judicial proceedings.

AU-12 — Audit Record Generation. `ias` generates audit records in real time for all configured events. A logging failure (e.g., due to buffer overflow) causes the operation itself to fail — the "Fail Secure" principle.

3.3 Assessment, Authorization, and Monitoring (CA)

3.3.1 `synrc/ca`: CA-2, CA-6, CA-7, CA-8, CA-9

CA-2 — Control Assessments. `synrc/ca` automates the collection of compliance evidence via the CMDB API. Before each audit (DSSZZI state exper-

tise), `mix run -e 'CA.TeX.generate()'` is executed, generating a complete documentation package from the current system state.

CA-6 — Authorization. System authorization is formalized through the L3 security profile (`legal_l3_profile_erp.pdf`), programmatically generated from the CMDB and cryptographically signed. Authorization is updated upon any significant architectural change.

CA-7 — Continuous Monitoring. Continuous monitoring is implemented through a triad: Wazuh SIEM (security events), Zabbix (availability and performance), and `synrc/ca` CMDB (configuration compliance). Any deviation from the recorded baseline state (CMDB drift) immediately generates an incident in `itsm`.

CA-8 — Penetration Testing. Regular penetration tests (at least annually) cover all ERP/1 components. Results are formalized as CMDB risk records and tracked through Plan of Action & Milestones (POA&M — control PM-4).

CA-9 — Internal System Connections. All internal connections between ERP/1 services are authorized via mTLS (mutual TLS) with certificates from `synrc/ca`. An unauthorized or non-certificated connection is technically impossible.

3.4 Configuration Management (CM)

3.4.1 `synrc/ca` CMDB: CM-2, CM-3, CM-6, CM-7, CM-8, CM-9

CM-2, CM-3 — Baseline Configuration and Configuration Change Control. The baseline configuration of all components is captured in CMDB Elixir modules (`hw.ex`, `sys.ex`, `net.ex`). Every change in the production environment must first be reflected in the corresponding CMDB file and pass Code Review in Git. Deviation from the baseline (configuration drift) is detected by Wazuh FIM (File Integrity Monitoring).

CM-6 — Configuration Settings. All ERP/1 services are launched with strict security hardening baselines: UA Linux DSTU-hardened, SELinux Enforcing, Windows Server DISA STIG. Deviations from baseline settings are technically blocked through SCM mechanisms (Puppet/Ansible).

CM-7 — Least Functionality. Each ERP/1 service runs only with the components required to perform its function. Unnecessary modules, protocols, and ports are disabled. The list of permitted components is documented in the corresponding `sys.ex` CMDB entry.

CM-8 — System Component Inventory. The `synrc/ca` CMDB is a "living" registry of all hardware, software, and network components. Each resource has a unique inventory number, bound to a cryptographic certificate and recorded in `hw.ex` or `sys.ex`.

CM-9 — Configuration Management Plan. Instead of a separate textual document, the CM plan is directly encoded in the Git repository: the CI/CD pipeline, Elixir CMDB modules, Ansible playbooks, and this PDF report together form a complete, self-verifying configuration management plan.

3.5 Contingency Planning (CP)

3.5.1 erlang/otp: CP-2, CP-7, CP-9, CP-10

CP-2 — Contingency Plan. Erlang/OTP is the foundation of ERP/1 fault tolerance. The Supervision Tree architecture guarantees the automatic restart of any failed process. At the cluster level, a minimum of three nodes (quorum) ensures availability even upon failure of one node.

CP-7 — Alternate Processing Site. Erlang/OTP supports hot failover between cluster nodes without loss of current sessions. The distributed process registry (`:pg` or via `synrc/kvs`) allows another node to take over processing upon primary node failure.

CP-9 — Information System Backup. `kvs` data is continuously replicated to all cluster nodes (synchronous Mnesia/RocksDB replication). Daily snapshots are written to a tape archive (HPE StoreEver) for offline storage.

CP-10 — Information System Recovery and Reconstitution. Recovery procedures are rehearsed as part of training (AT-3) in an isolated environment. The built-in `:hot_code_upgrade` function allows components to be updated without system downtime, minimizing RTO (Recovery Time Objective).

3.6 Identification and Authentication (IA)

3.6.1 synrc/ca + zencrypted/ias: IA-2, IA-5, IA-8

IA-2 — Identification and Authentication (Organizational Users). `ias` enforces strict MFA: the first factor is an X.509 certificate (smart card or IIT Gryada HSM token), the second factor is an OTP (TOTP/HOTP or hardware token). No system function is accessible without successful completion of both factors.

IA-2(1) — MFA for Privileged Accounts (Network Access). Administrative accounts additionally require a third factor — push-notification confirmation on a registered device. Login from a "shared" device is technically blocked.

IA-2(2) — MFA for Non-Privileged Accounts. Standard users authenticate with a minimum of two factors. The first is a certificate on a smart card (PKCS#15, DSTU 4145-2002 algorithm), the second is the smart-card PIN.

IA-5 — Authenticator Management. `synrc/ca` is the authoritative source of cryptographic authenticators (certificates). Management includes: enrollment (Certificate Enrollment via EST), renewal (ACME/CMP), revocation (OCSP/CRL), and archiving (Long-Term Validation, LTV). All authenticators are bound to a hardware carrier (e-Token, Gryada-301).

IA-5(1) — Password-Based Authentication. For service accounts where passwords are still used, `ias` enforces minimum complexity and stores passwords in Argon2id format (PHC winner, resistant to GPU attacks). Passwords are never transmitted in plaintext.

IA-8 — Identification and Authentication (Non-Organizational Users).

For external systems (e.g., Unified State Register, Diia), **ias** supports identity federation via SAML 2.0 and OIDC, where the external IdP verifies the identity and **ias** issues a local token with limited rights based on attributes received from the external provider.

3.7 Incident Response (IR)

3.7.1 erpuno/itsm: IR-1, IR-4, IR-5, IR-6

IR-1 — Incident Response Policy and Procedures. Incident response processes are formalized as BPMN processes in **synrc/bpmn** and executed via **erpuno/itsm**. Each incident type (with its MITRE ATT&CK code) has an assigned BPMN template with clear stages: detection, classification, escalation, remediation, post-analysis.

IR-4 — Incident Handling. **itsm** automatically receives incidents from Wazuh (via webhook) and **ias** (upon detecting anomalies per AC-2(12)). Each incident receives a unique INC identifier, bound to the CMDB record of the affected component.

IR-5 — Incident Monitoring. The complete audit trail of each incident (all actions, comments, status changes) is stored in **kvs** and available for query. Retention period is a minimum of 3 years.

IR-6 — Incident Reporting. **itsm** automatically generates monthly incident reports in PDF format (using the **synrc/ca** LaTeX generator) and forwards them to the CISO and the relevant regulator (DSSZZI).

3.8 Maintenance (MA)

3.8.1 erpuno/itsm: MA-2, MA-4, MA-5

MA-2 — Controlled Maintenance. Any scheduled maintenance work (server, network equipment, HSM servicing) is registered as a Change Request (CR) in **itsm**. A CR has mandatory fields: **maintainer_id**, **authorization_certificate** (X.509 signature from an authorized engineer), **maintenance_window**, **rollback_plan**.

MA-4 — Nonlocal Maintenance. All remote maintenance access (SSH, RDP) is routed through a dedicated Jump server in the Management VLAN. Access to the Jump server is possible only from fixed IPs via an **synrc/vpn** tunnel with mandatory MFA.

MA-5 — Maintenance Personnel. The list of authorized maintenance personnel is maintained in the CMDB (**roles.ex**) and verified by **ias** before granting access. Non-certified personnel are technically unable to access the systems.

3.9 Media Protection (MP)

3.9.1 synrc/kvs: MP-2, MP-4, MP-5, MP-6, MP-7

MP-2, MP-4 — Media Access and Storage. `kvs` is the primary storage for all critical ERP/1 data. Data is encrypted at the record level using DSTU algorithms (Kalyna AES-256 GCM) with keys stored in an IIT Gryada HSM. Physical access to servers running `kvs` is restricted via the Policy Engine and PE controls.

MP-5 — Media Transport. Tape backups (HPE MSL3040) are encrypted before writing. Physical tapes are stored in a safe with dual control. The procedure for removing a tape from the perimeter requires an authorized CR in `itsm`.

MP-6 — Media Sanitization. The sanitization procedure (DoD 5220.22-M or physical destruction for SSD/flash) is documented in `itsm` and recorded in the CMDB as a component de-inventory event.

MP-7 — Media Use. Removable media (USB) usage is technically blocked at the OS level (`udev` rules, Group Policy) for all workstations, except specifically authorized technical workstations with CISO approval.

3.10 System and Communications Protection (SC)

3.10.1 synrc/vpn: SC-7, SC-8, SC-12, SC-28

SC-7 — Boundary Protection. `synrc/vpn` implements a strict network perimeter based on IPsec IKEv2 with X.509 certificate authentication. All external connections (between sites, with remote users) pass through VPN tunnels. The Cisco Firepower 4145 NGFW (documented in CMDB) filters traffic at the perimeter.

SC-7(3) — Access Points. The number of external network connections is minimized and strictly documented in the `net.ex` CMDB. Each new access point requires a separate CR and CISO approval.

SC-8 — Transmission Confidentiality and Integrity. All traffic between ERP/1 components is protected by mTLS 1.3 with mandatory DSTU-compatible cipher suites. Unencrypted traffic is technically impossible — `ias` rejects requests without a valid TLS certificate.

SC-12 — Cryptographic Key Establishment and Management. `synrc/ca` is the authoritative key center. Root keys are stored exclusively in the HSM (Gryada-301) and never leave the hardware module. Key rotation is performed according to the Key Ceremony procedure with Dual Control.

SC-28 — Protection of Information at Rest. PostgreSQL and Oracle use TDE (Transparent Data Encryption) with keys from the HSM. `kvs` performs additional encryption at the record level.

3.11 System and Information Integrity (SI)

3.11.1 `synrc/chat`: SI-3, SI-4, SI-7, SI-10

SI-3 — Malicious Code Protection. All cluster nodes are protected by Wazuh HIDS with up-to-date signatures. At the CI/CD pipeline level, automatic dependency scanning (SBOM, OWASP Dependency Check) is executed on every commit.

SI-4 — System Monitoring. The combination of Wazuh (security events) and Zabbix (performance metrics) provides 24/7 monitoring of all components. The Wazuh event correlator detects attack patterns (MITRE ATT&CK) and automatically escalates them to `itsm`.

SI-7 — Software, Firmware, and Information Integrity. All ERP/1 releases are signed with a DSTU 4145-2002 digital signature from `synrc/ca` and published together with signatures. Checksums (DSTU 7564-2014 Kupyna-512) are verified before installing any update.

SI-10 — Information Input Validation. `synrc/chat` and all ERP/1 web components (via `synrc/ws`) apply strict schema validation (JSON Schema / XSD) of input data at the API Gateway level before passing it to business logic.

3.12 Supply Chain Risk Management (SR)

3.12.1 `synrc/chat` + `synrc/ca`: SR-3, SR-4, SR-11

SR-3 — Supply Chain Controls and Processes. ERP/1 uses exclusively open-source components (Erlang/OTP, Elixir), whose source code is verified before inclusion. An SBOM (Software Bill of Materials) is generated automatically at every build.

SR-4 — Provenance. All components have cryptographically verified provenance. Release signatures are verified through the `synrc/ca` root CA. An undocumented or unsigned component cannot be installed in the production environment.

SR-11 — Component Authenticity. Hardware components (HSM, switches, servers) are verified via serial number and CMDB inventory record. Vendors (5HT Technology, IIT, Cisco) have signed supply chain security agreements.

3.13 Planning, Risk Assessment, System Acquisition, Privacy (PL, RA, SA, PM, PT)

3.13.1 `synrc/ca` CMDB: PL-2, RA-2, RA-3, SA-5, PM-2, PM-5, PM-6, PT-2, PT-4

PL-2 — System Security and Privacy Plans. This very PDF report, generated programmatically from the CMDB and LaTeX templates, serves as the ERP/1 system security plan. It is updated automatically upon every architectural change (recorded in Git).

RA-2 — Security Categorization. ERP/1 data categorization (Public, PII, Internal, Confidential) is implemented in the `data.ex` CMDB module and automatically bound to cryptographic protection requirements and access controls.

RA-3 — Risk Assessment. The `risk.ex` CMDB risk register contains more than 40 documented threats (RISK-OS-01 through RISK-DAT-02), mapped to specific NIST control families and automatically included in compliance analysis.

SA-5 — System Documentation. All ERP/1 architectural and security documentation is generated automatically from source code (Documentation as Code). This eliminates the "documentation drift" phenomenon and guarantees that auditors always assess the current state of the system.

PM-2, PM-5, PM-6 — Security Program, System Inventory, and Performance Measures. The ERP/1 security program is materialized in the `synrc/ca` CMDB: roles (PM-2), system inventory (PM-5), and key security performance indicators (PM-6) are directly queryable through the CMDB API.

PT-2, PT-4 — Authority and Consent for PII Processing. Processing of personal data (CA subscriber registry) is conducted exclusively within the purposes declared in the Certificate Practice Statement (CPS). The data subject's consent is recorded in `kvs` with a cryptographic signature.

4 Organizational Security Profile

4.1 Awareness and Training

4.1.1 `synrc/ca`: AT-2, AT-3 — Security Awareness and Role-Based Training

`synrc/ca` serves as a platform for role-based security training (AT-3). Specifically, for CA operators, a simulation mode is implemented where all signing operations occur on a test HSM with test keys. This allows critical procedures (Key Ceremony, OCSP operations) to be rehearsed without risk to the production environment.

AT-2(2) — Phishing Simulations. Integration of `ias` with the ERP/MAIL module allows automated sending of simulated phishing emails and recording of user responses. Results are automatically bound to user profiles in `ias` and influence the subject's risk assessment score.

5 Conclusion

By treating the Information Security Management System (ISMS) and the KSZI documentation as "Infrastructure as Code" (IaC) via Elixir maps, ERPUNO LLC achieves a continuous, verifiable, and strictly compliant security posture. This approach significantly reduces the friction typically associated with DSSZZI and NIST audits by ensuring that the actual state of the system is always perfectly synchronized with its certified documentation.

5.1 Codebase Overview for Copyright Registration

The entire Configuration Management Database (CMDB), Continuous Accountability System, and PKI Certificate Authority components discussed in this document are implemented as a cohesive software suite. This software suite forms the basis for the formal registration of the copyright work.

The core architectural blocks of the codebase include:

- **SYS-SYNRC-CA:** The central Certificate Authority and HSM backend responsible for issuing X.509 certificates, OCSP, CRLs, and managing the entire PKI lifecycle via ACME and EST protocols.
- **CMDB Profiles:** The declarative Elixir modules defining the precise state of hardware (`hw.ex`), network topology (`net.ex`), and system applications (`sys.ex`).
- **Policy and Risk Engines:** Modules responsible for automated data categorization (`data.ex`), dynamic risk taxonomies (`risk.ex`), and strict role-based/attribute-based access controls (`roles.ex`, `abac.ex`).

The software is continuously developed, documented, and published at the following official resources:

- **Source Code Repository:** <https://github.com/synrc/ca>
- **Official Product Portal:** <https://erp.uno/ca/>
- **Developer Documentation:** <https://ca.n2o.dev>

References

- [1] National Institute of Standards and Technology. *Security and Privacy Controls for Information Systems and Organizations*. NIST Special Publication 800-53, Revision 5.
- [2] Державна служба спеціального зв'язку та захисту інформації України. *НД ТЗІ 3.7-003-2023. Порядок проведення державної експертизи в сфері технічного захисту інформації*.
- [3] Державна служба спеціального зв'язку та захисту інформації України. *НД ТЗІ 2.5-004-99. Критерії оцінки захищеності інформації в комп'ютерних системах від несанкціонованого доступу*.
- [4] International Organization for Standardization. *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.